TCC AWS · STARTUP XYZ · GESTÃO DE DOCUMENTOS PARA IA

Manual da demonstração na AWS

Como recriar a arquitetura do zero, rodar a demonstração do slide 14 e onde encontrar no console cada configuração que a banca pode pedir para ver. Todos os prints são da conta do grupo, em São Paulo, feitos em 29/09/2026.

sa-east-1
Região (São Paulo)

26
Recursos criados pelo template

~2 min
Tempo do deploy

~US$ 1/mês
Custo da demo parada (chave KMS)

00

O que a demo prova

O guia pede "mostre funcionando". Cada linha abaixo é um requisito do TCC com a evidência real que a demonstração produz.

REQUISITO	EVIDÊNCIA NA DEMO	RESULTADO
Só usuário autenticado usa a API	Chamada sem token e com JWT forjado	`401` no API Gateway
Arquivo não passa pelo backend	Upload direto no S3 com URL pré-assinada	`204` gravado no prefixo do usuário
Usuário A nunca vê o B (1ª camada)	cliente-a pede a chave do cliente-b	`403` checagem da aplicação
Usuário A nunca vê o B (2ª camada)	Mesmo ataque com a checagem desligada (bug simulado)	`403 AccessDenied` do S3
Histórico preservado a custo baixo	Documento em Deep Archive e pedido de restauração	`409 → 202` restauração solicitada
Dados cifrados	Detalhe do objeto no console	SSE-KMS com chave própria

REQUISITO	EVIDÊNCIA NA DEMO	RESULTADO
Auditoria	CloudTrail e logs de acesso da API	Cada credencial e cada chamada registradas
Recriável do zero (replicação)	Template CloudFormation + README	Deploy em ~2 min

01

Antes de começar

1. **Conta AWS ativa, região São Paulo.**
   No canto superior direito do console, selecione *América do Sul (São Paulo)*. Se todo serviço abrir a tela "Complete your account setup", o cadastro ainda não terminou (no nosso caso era o cartão).

2. **Python 3 no computador que vai apresentar.**
   Serve só para abrir a página da demo em `localhost:8000`.

3. **Pasta `demo-aws/` do projeto.**
   `infra/template.yaml` (a infraestrutura), `app/` (página e PDFs de teste), `lambda/app.py` (código legível) e `README.md`.

Conta root

Fizemos tudo com o usuário root, o que é aceitável numa demo, mas a banca pode perguntar. A boa prática é ativar MFA no root e trabalhar com um usuário do IAM Identity Center. Isso é configuração de segurança da conta: quem faz é o dono dela.

Plano gratuito e GuardDuty

O plano gratuito da AWS bloqueia o GuardDuty. Ele continua no desenho da arquitetura (escaneia cada upload; o parâmetro `EnforceMalwareScan` faz o app ler só arquivos limpos), mas não entra na demo.

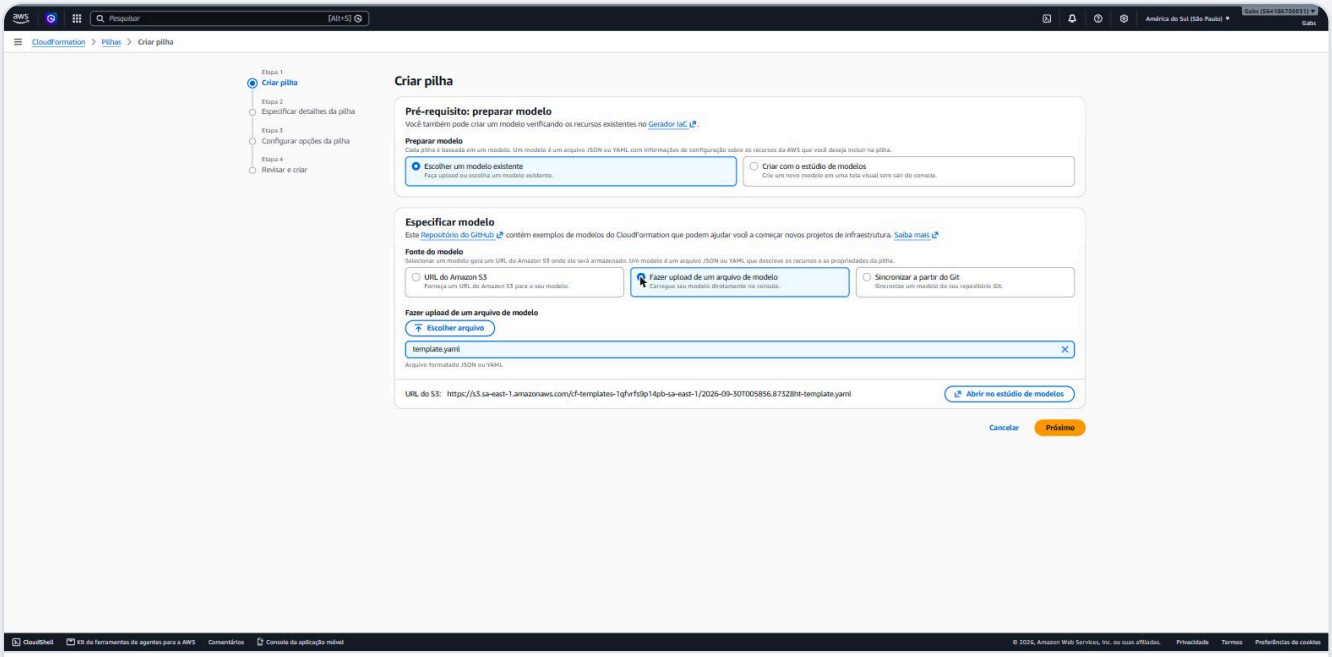
02

Criar a infraestrutura

Um único arquivo cria Cognito, API Gateway, Lambda, as roles do IAM, a chave KMS, o bucket S3 com todas as proteções, alarmes e o dashboard.

1 **CloudFormation → Criar pilha.**

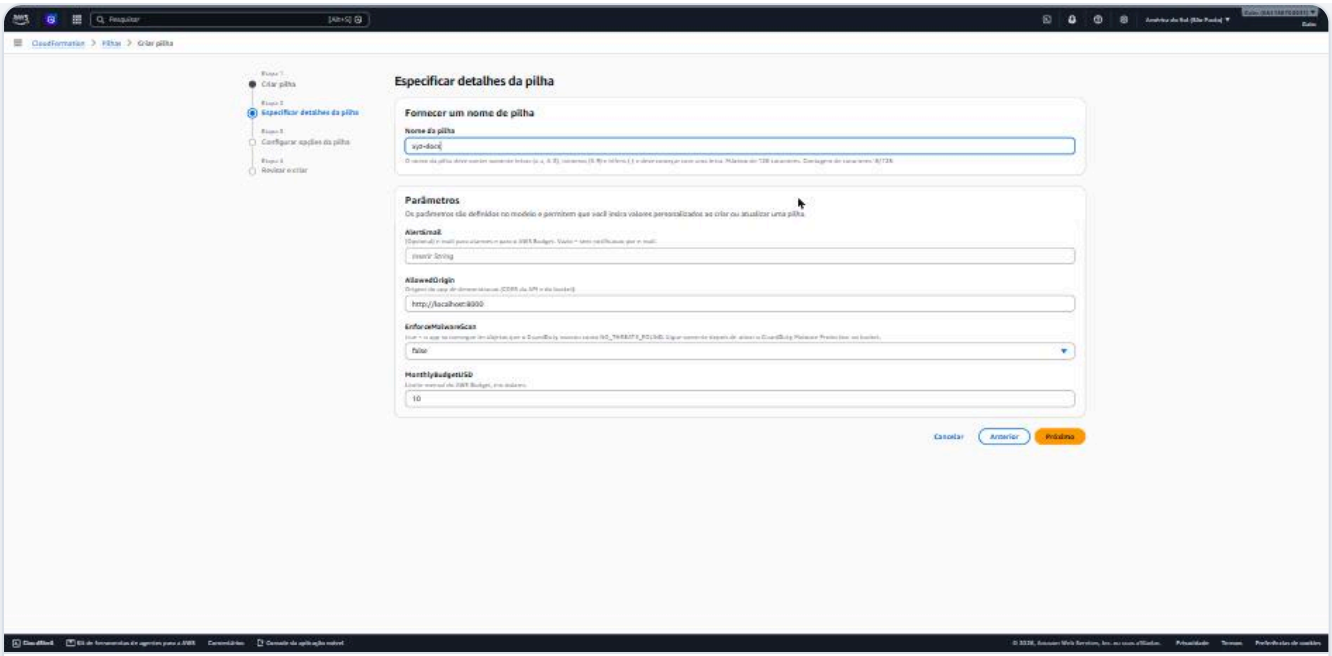
Escolha *Fazer upload de um arquivo de modelo* e envie `infra/template.yaml`.



02 **Upload do modelo.** O console guarda o arquivo num bucket `cf-templates-…` e mostra a URL.

2 **Nome da pilha: `xyz-docs`.**

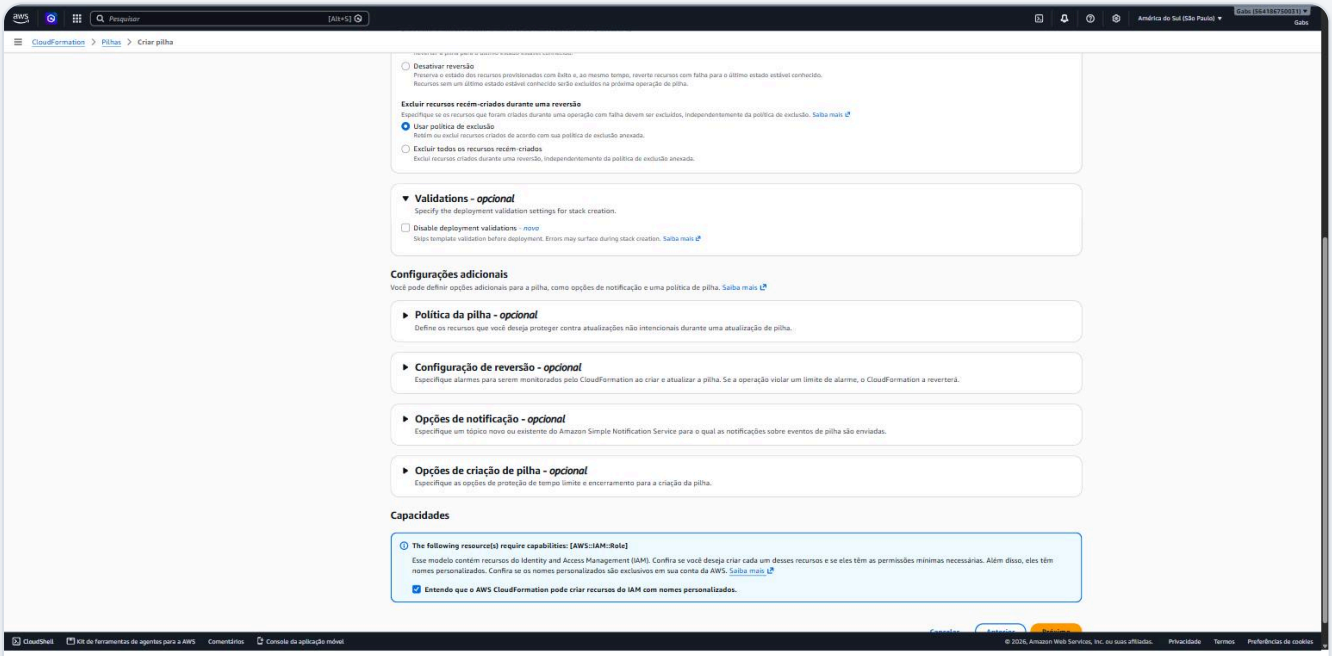
Deixe os parâmetros no padrão. `AlertEmail` vazio significa sem e-mail de alerta; preencha para ativar alarmes por e-mail e o AWS Budget.



03 **Parâmetros.** `AllowedOrigin` é a origem da página da demo, liberada no CORS da API e do bucket.

3 Etapa 3: role até o fim e marque a caixa de capacidades do IAM.

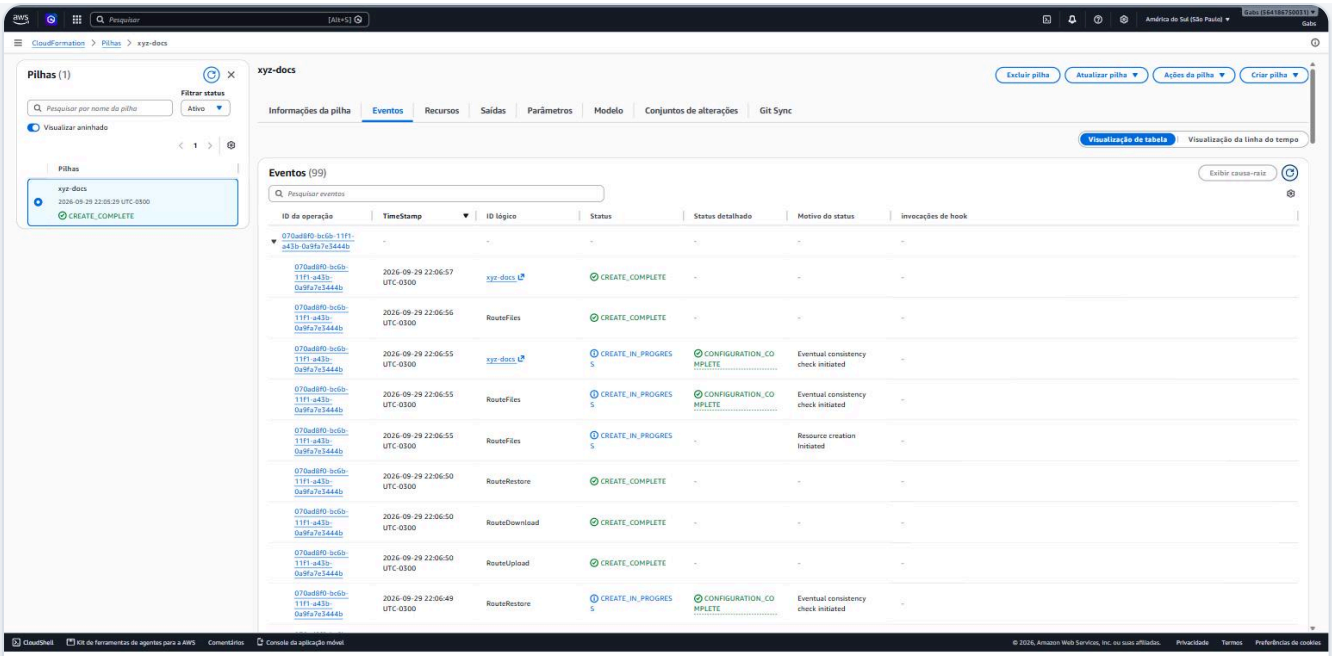
O template cria roles com nome fixo (`xyz-user-access-role`), por isso o aviso. Depois, *Próximo* e *Enviar*.



04 **Capacidades.** Sem essa caixa marcada o botão avança mas a criação é recusada.

4 Aguarde `CREATE_COMPLETE` .

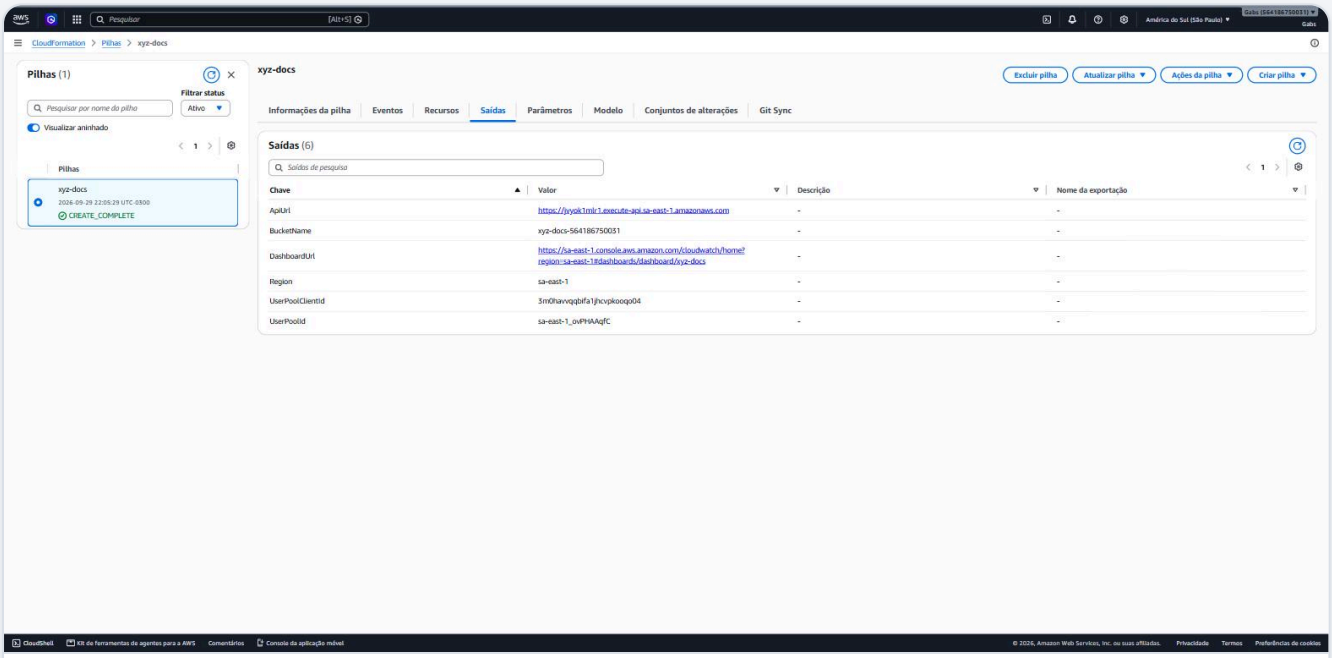
Levou cerca de 1 min 30 s.



05 **Pilha criada.** 99 eventos, nenhuma falha.

5 **Aba Saídas: anote `ApiUrl`, `UserPoolClientId` e `Region`.**

São os três valores que a página da demo pede.



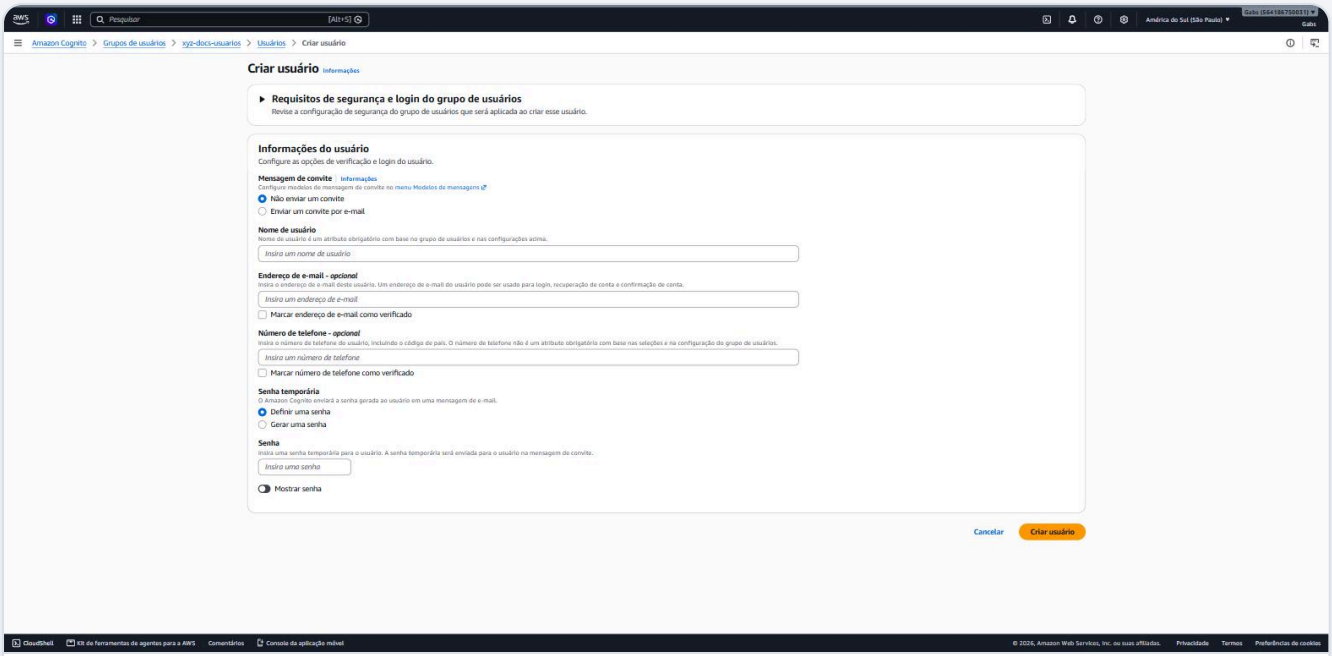
06 **Saídas.** Também trazem o nome do bucket e o link do dashboard do CloudWatch.

03

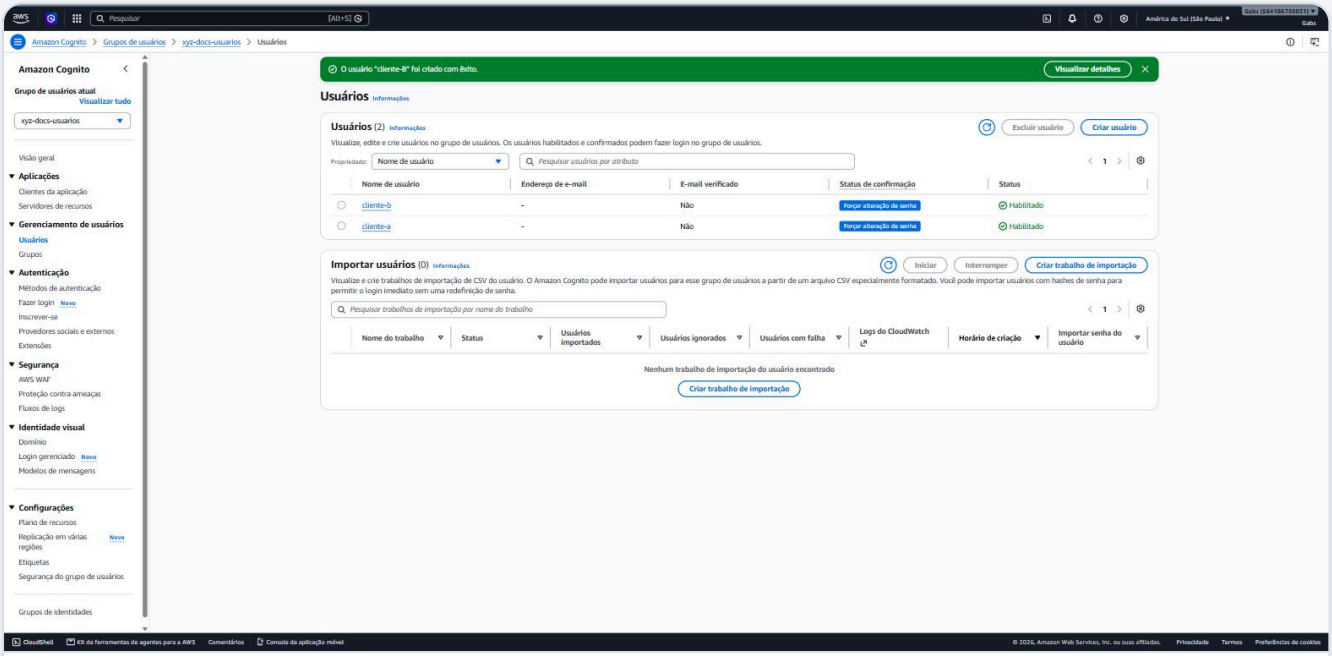
Criar os usuários de teste

1 **Cognito → grupo `xyz-docs-usuarios` → Usuários → Criar usuário.**

"Não enviar um convite", nome `cliente-a` (tudo minúsculo), "Definir uma senha" (mín. 8, com minúscula e número). Ligue *Mostrar senha* para conferir antes de salvar. Repita para `cliente-b`.



14 **Criar usuário.** E-mail e telefone não são necessários.



22 **Usuários criados.** O status "Forçar alteração de senha" é normal: no primeiro login a página pede uma senha nova.

Erro "Incorrect username or password"

Aconteceu conosco: a senha gravada não era a que achávamos. O Cognito não mostra a senha salva, então exclua o usuário e crie de novo com *Mostrar senha*

ligado. Apague também o campo Senha da página antes de digitar, porque o Chrome pode preencher sozinho.

04

Roteiro da demonstração

Para o bloco do Lucas (slide 14). Faça os logins antes de a apresentação começar: o token vale 60 minutos.

Preparar (antes da banca)

1. **Abrir a página.**

   ```
   cd demo-aws/app
   python -m http.server 8000 --bind 127.0.0.1
   ```

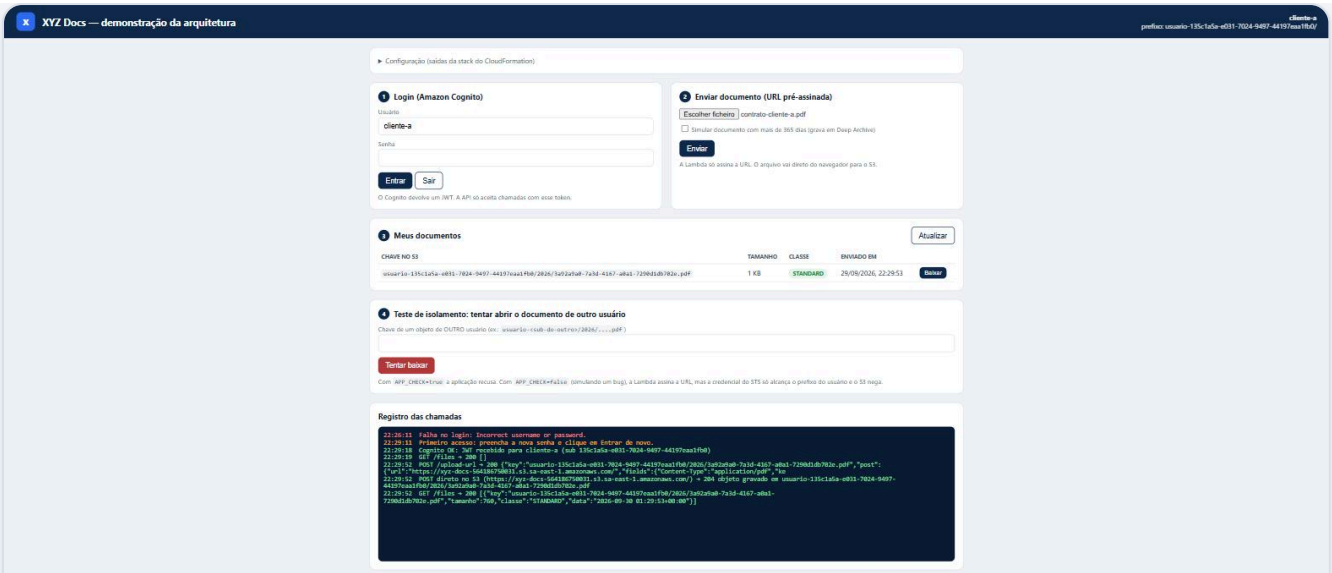
   Abra `http://localhost:8000`. Na primeira vez, preencha *Configuração* com as saídas da pilha e clique em Salvar.

2. **Duas abas, uma por cliente.**
   Faça login como `cliente-a` numa aba e `cliente-b` na outra. Não recarregue as abas depois do login.

3. **Deixar o console aberto em outra aba** na Lambda `xyz-docs-autoriza` → Configuração → Variáveis de ambiente.

1. Upload direto no S3

Na aba do cliente-a, escolha `amostras/contrato-cliente-a.pdf` e clique em Enviar. No cliente-b, envie `nota-fiscal-cliente-b.pdf`.

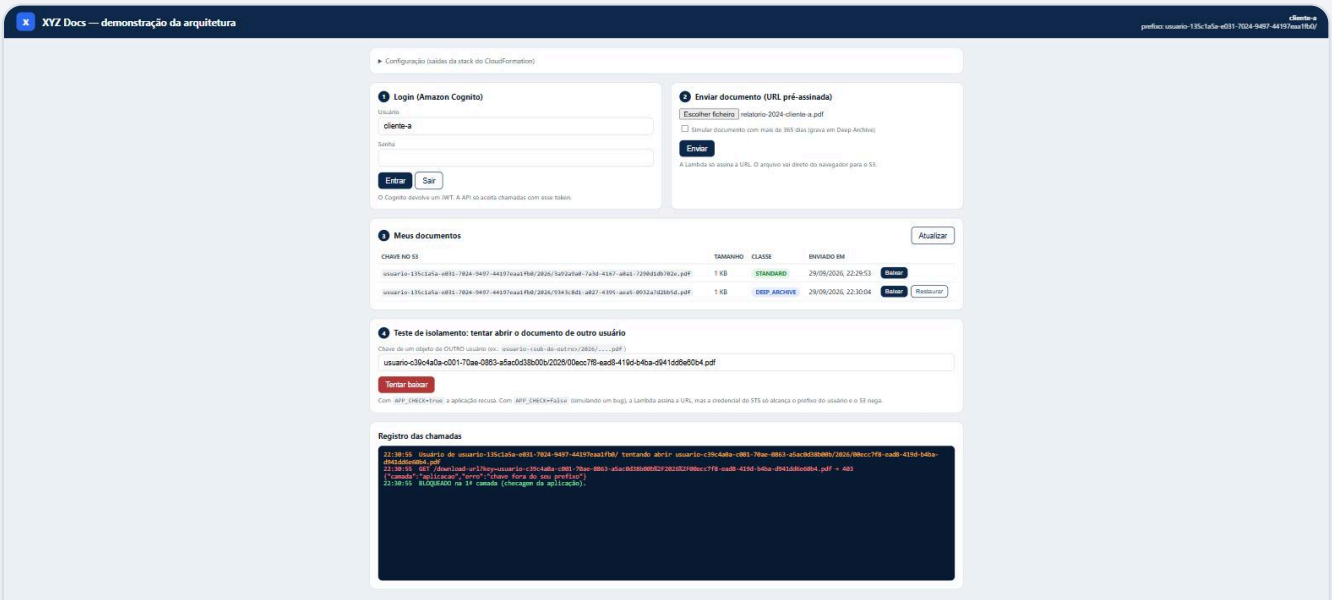


23 **Upload.** A API devolve a URL; o navegador grava direto no S3 (`204`) dentro de `usuario-<sub>/2026/` .

> FALA SUGERIDA
>
> *A Lambda não recebeu o PDF. Ela só confirmou quem é o usuário e devolveu uma URL válida por 15 minutos. O arquivo foi direto do navegador para o S3, dentro da pasta desse usuário.*

2. Ataque, primeira camada

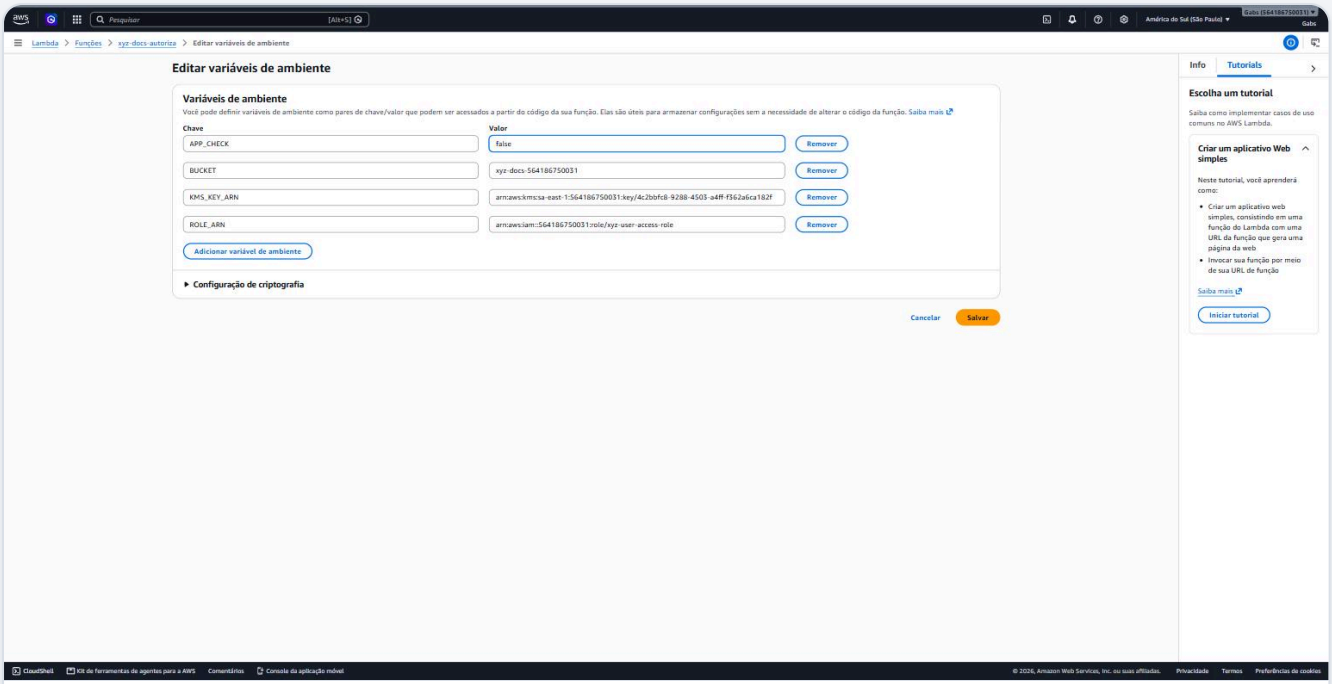
Copie a chave do arquivo do cliente-b (lista "Meus documentos" da aba dele), cole no campo 4 da aba do cliente-a e clique em *Tentar baixar*.



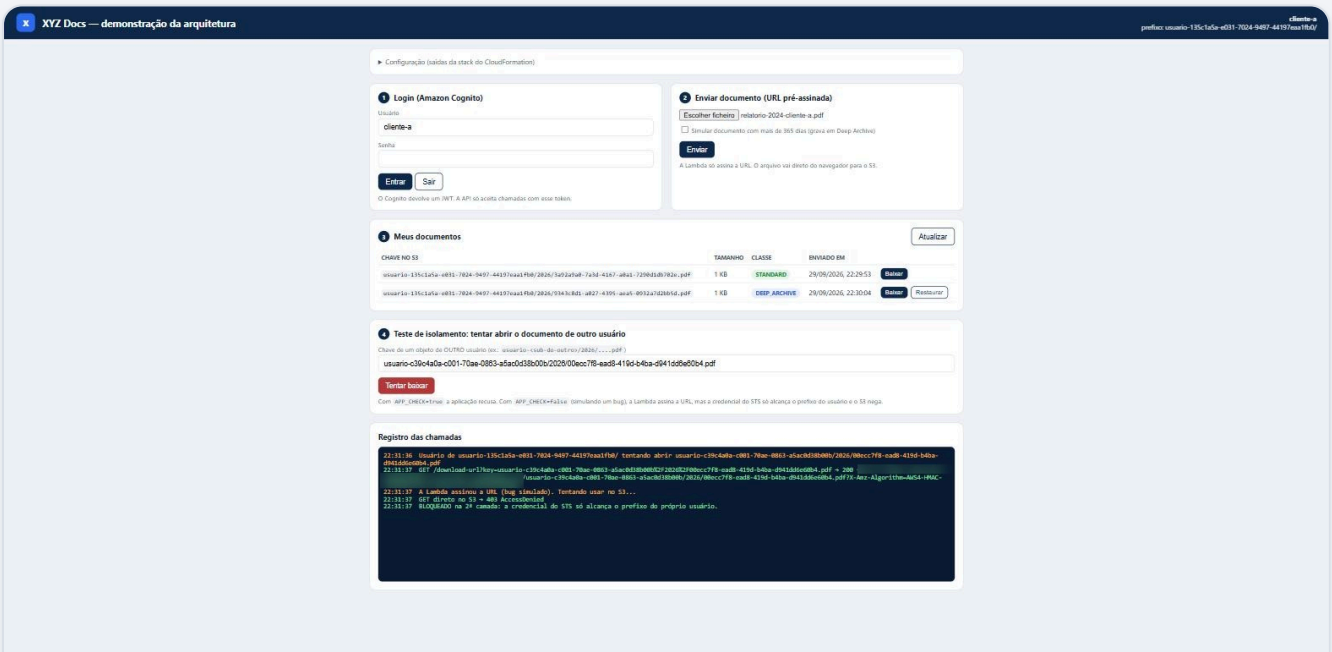
24 **Bloqueado pela aplicação.** `403 "chave fora do seu prefixo"` .

3. Ataque, segunda camada (bug simulado)

No console, mude `APP_CHECK` para `false` e salve. Repita o ataque.



25 **Checagem desligada.** Simula um desenvolvedor que esqueceu de validar a chave (IDOR).



26 **Bloqueado pela credencial.** A Lambda assinou a URL, mas o S3 respondeu `403 AccessDenied`.

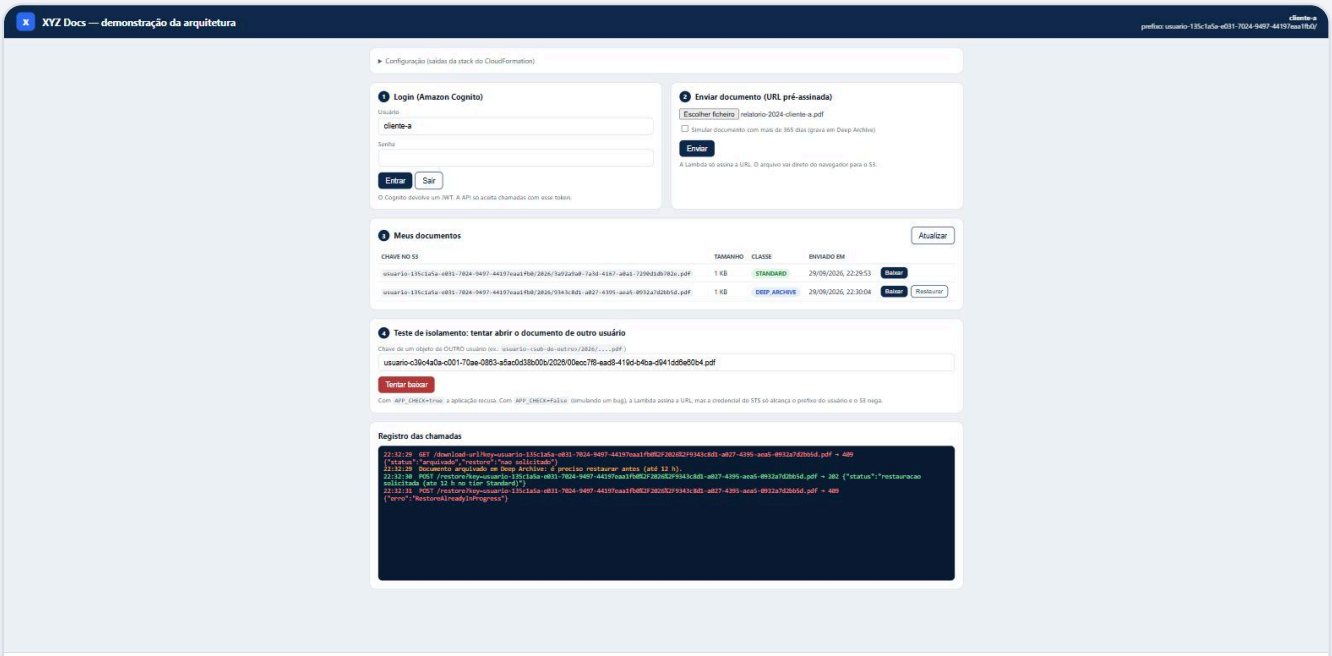
> FALA SUGERIDA
>
> *Desligamos a checagem da aplicação para simular um bug. Mesmo assim o S3 negou, porque a credencial que assinou a URL foi emitida pelo STS só para a pasta do cliente-a. O isolamento não depende de o código lembrar de checar.*

Não esqueça

Volte `APP_CHECK` para `true` logo depois.

4. Documento antigo em Deep Archive

No cliente-a, marque "Simular documento com mais de 365 dias", envie `relatorio-2024-cliente-a.pdf`, depois clique em Baixar e em Restaurar nessa linha.

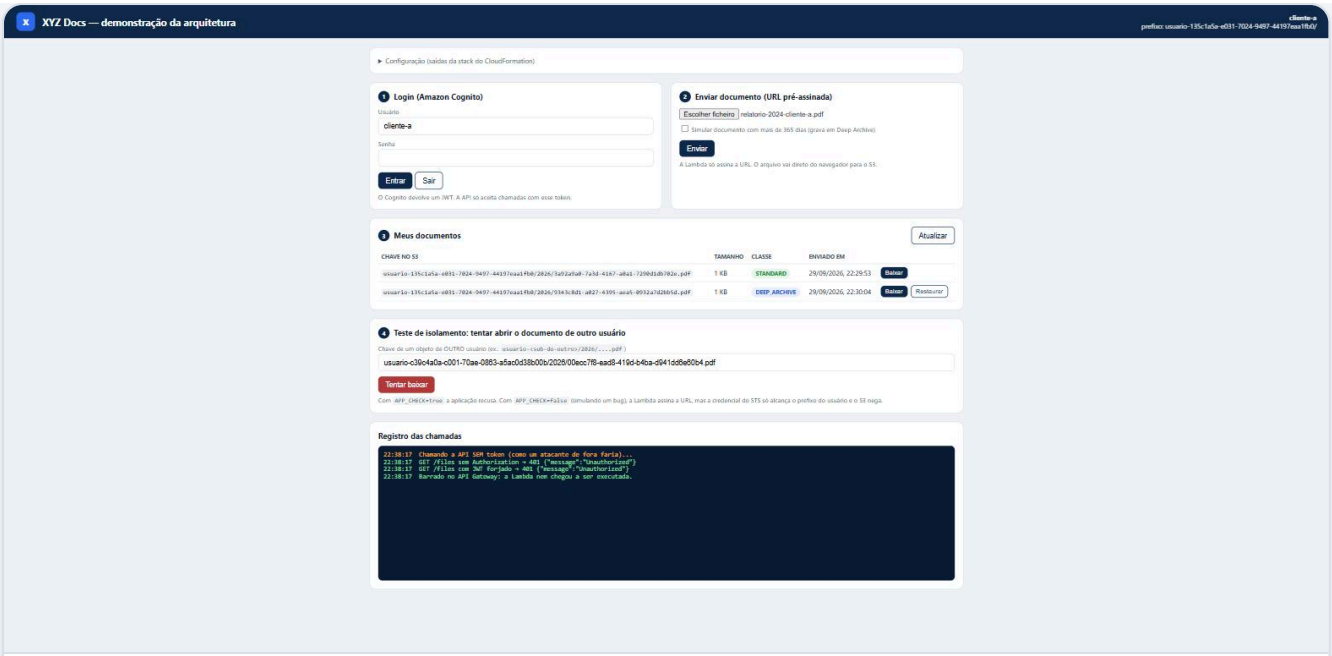


27 **Ciclo de vida.** Download recusado com `409 arquivado`; restauração aceita com `202`; um segundo pedido retorna `RestoreAlreadyInProgress`.

> FALA SUGERIDA
>
> *Depois de um ano o documento vai para o Deep Archive, que custa cerca de 4% do armazenamento padrão. Ele não some: o cliente pede a restauração e o arquivo volta em até 12 horas.*

5. Sem login não entra

Opcional, 20 segundos: botão *Chamar a API sem login* no bloco 4. Ele faz uma chamada sem token e outra com um JWT forjado.



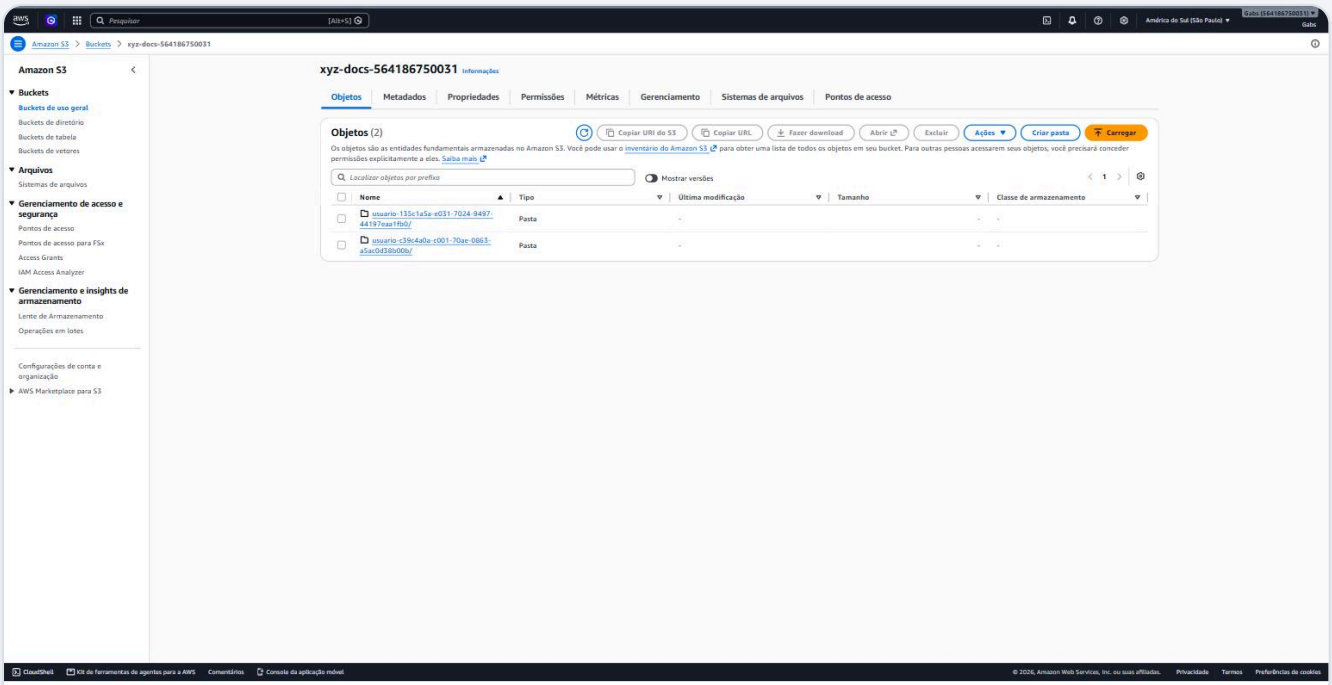
36 **401 no API Gateway.** A Lambda nem é executada, então não há custo nem superfície de ataque no código.

05

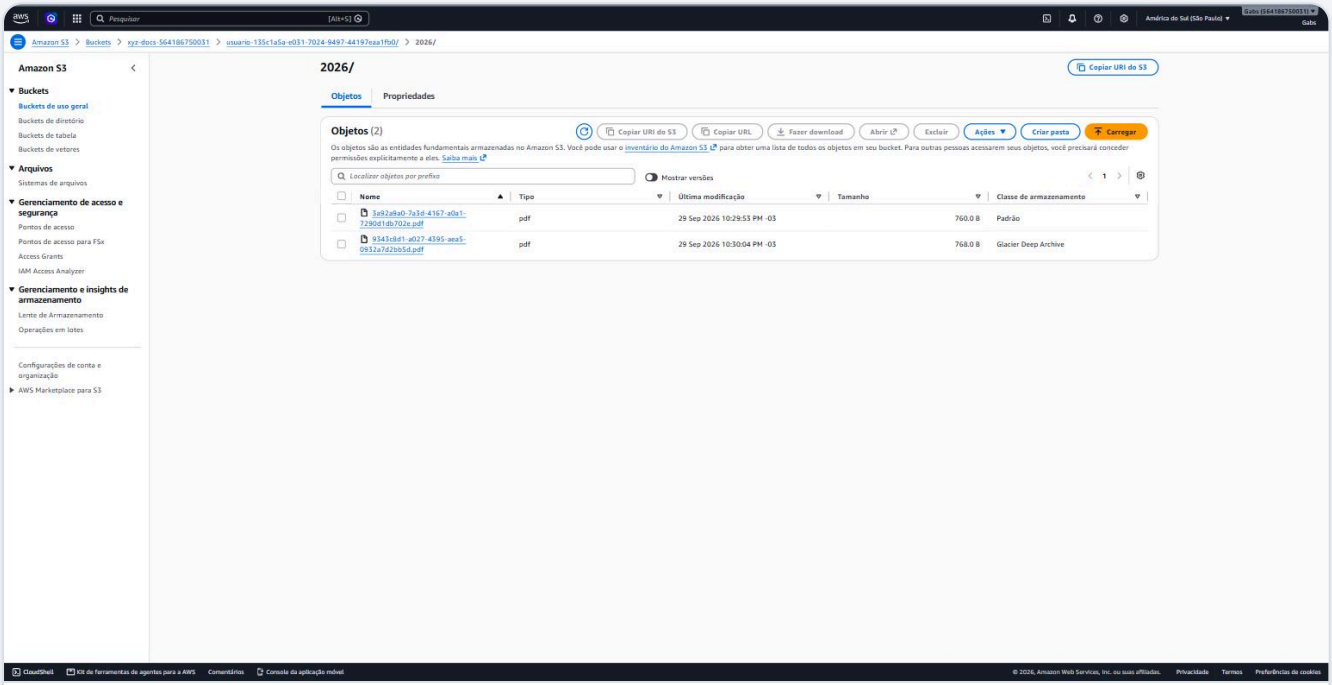
Tour pelo console

Onde encontrar cada configuração se a banca pedir. Organizado pelos pilares do guia.

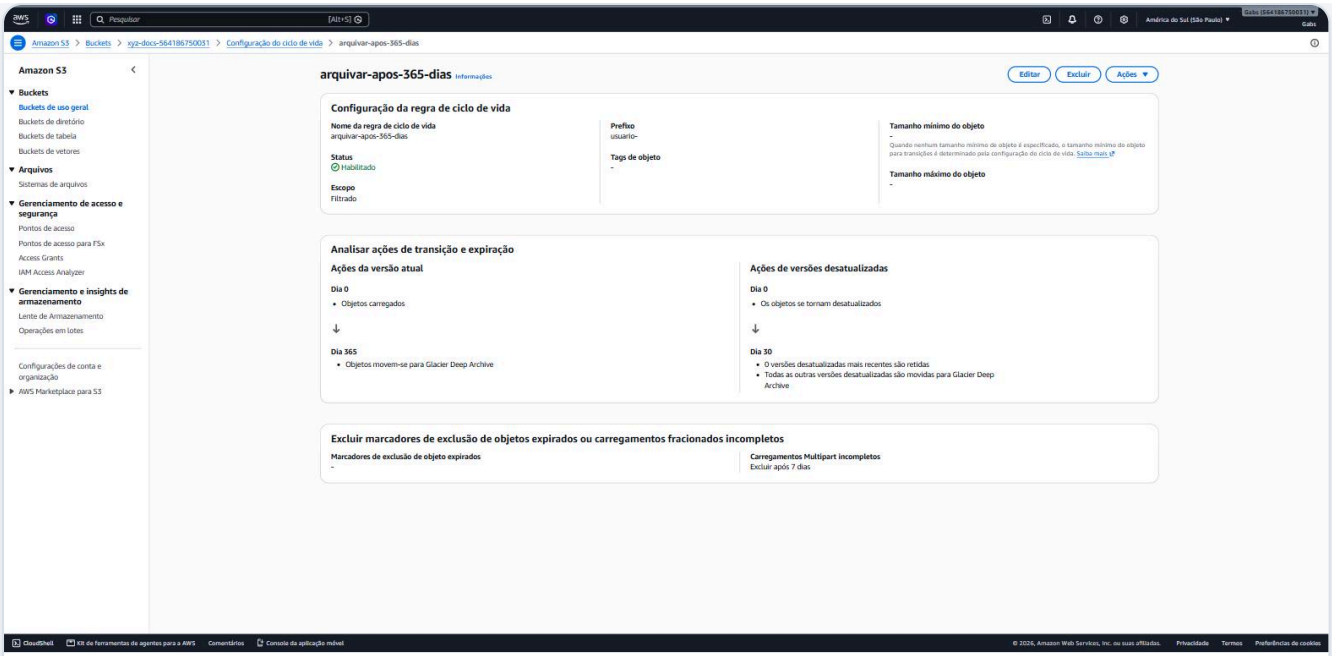
Armazenamento e ciclo de vida (S3)



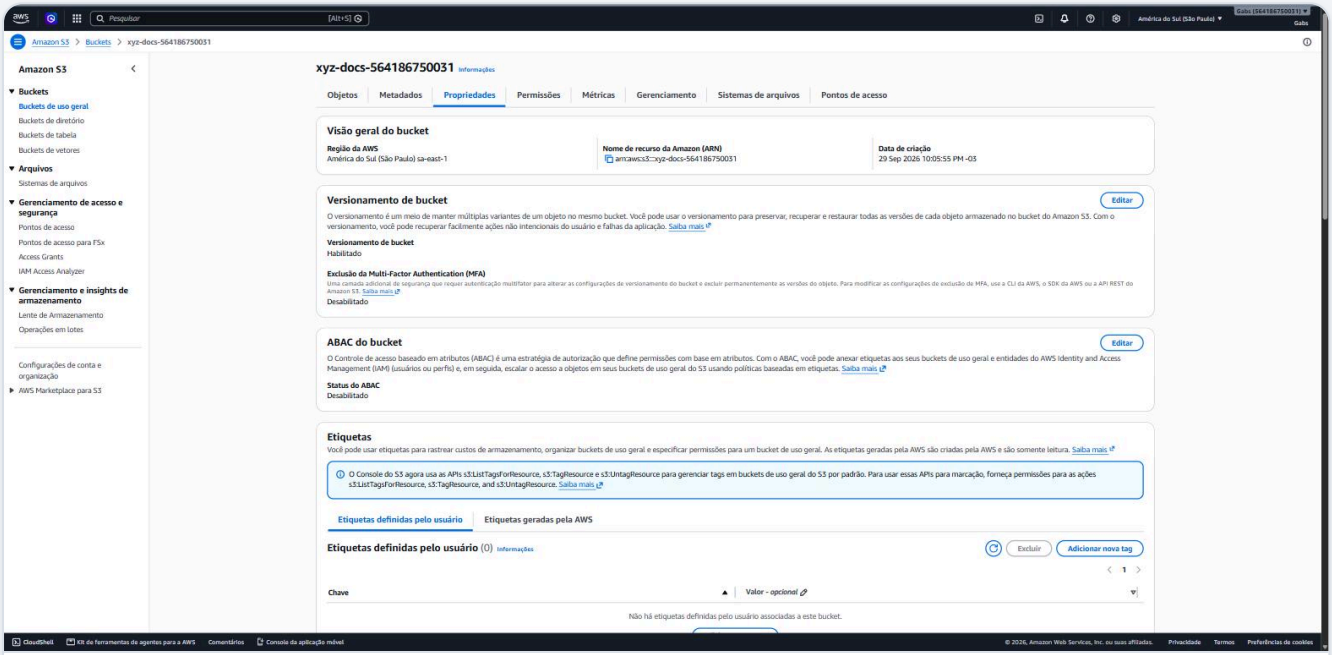
28 **Um prefixo por usuário.** S3 → bucket `xyz-docs-…` → Objetos. O nome da pasta é o `sub` do Cognito.



29 **Classes de armazenamento.** Mesmo bucket, mesmo prefixo: um objeto em Padrão e outro em Glacier Deep Archive. O nome do arquivo é um UUID gerado no servidor.

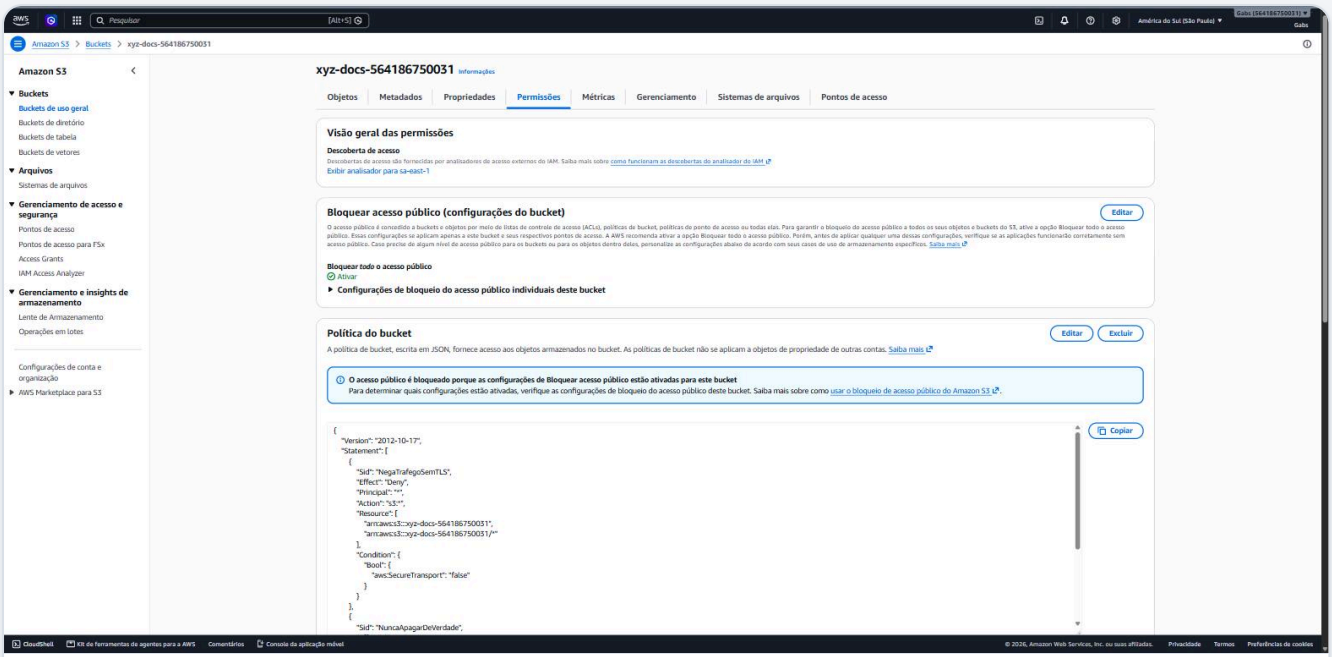


12 **Lifecycle.** Gerenciamento → regra `arquivar-apos-365-dias` : dia 365 para Deep Archive; versões antigas vão para Deep Archive em 30 dias em vez de serem apagadas; upload incompleto é limpo em 7 dias.

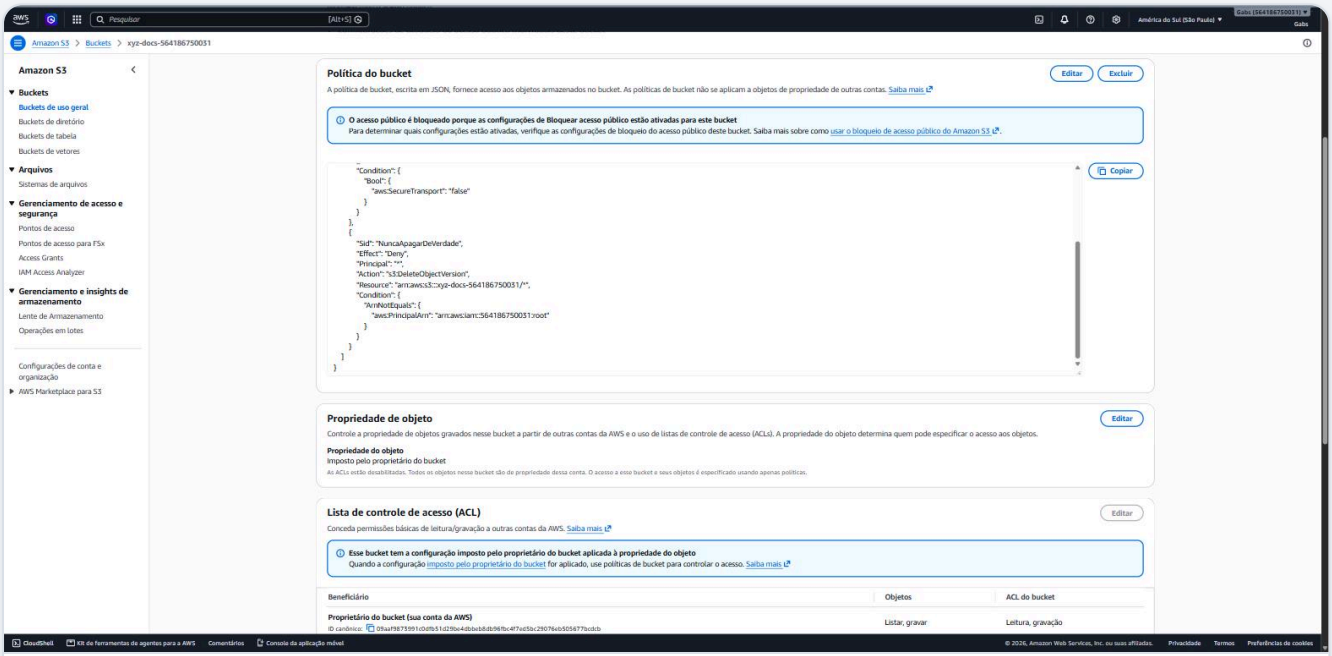


07 **Versionamento.** Propriedades. Sobrescrita ou exclusão acidental pode ser desfeita.

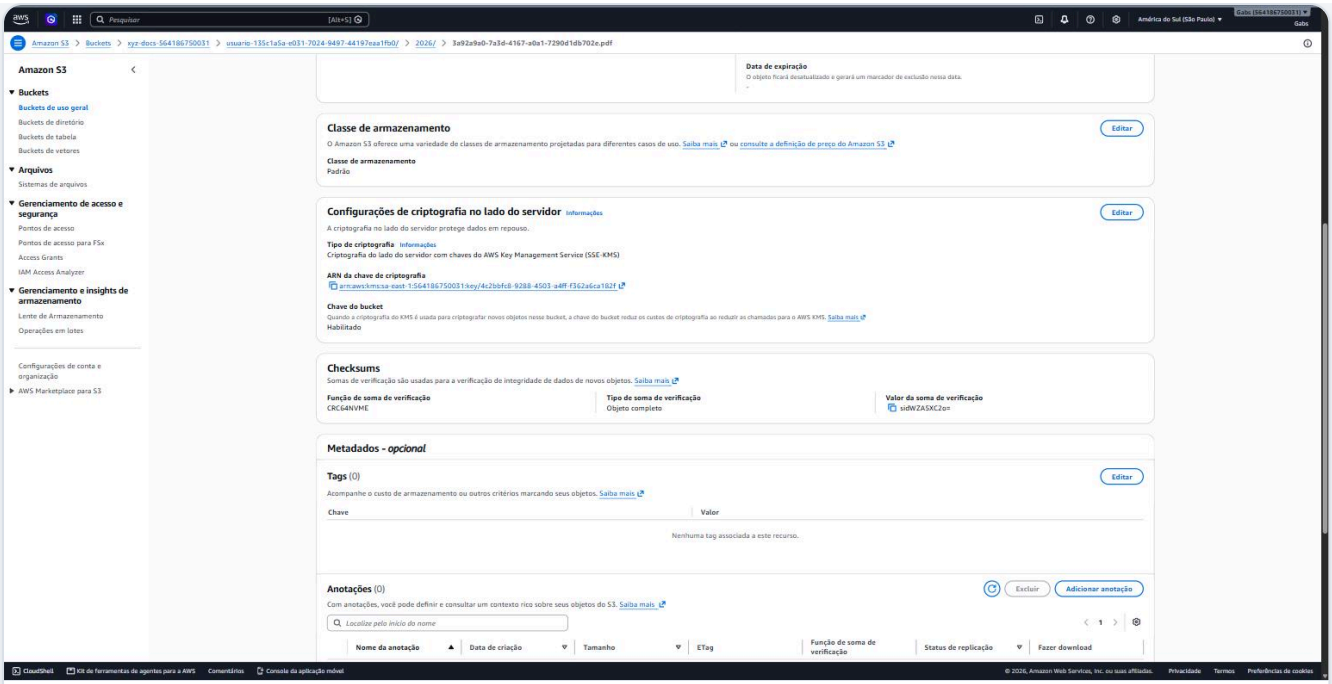
Segurança dos dados



09 **Bloqueio de acesso público e política do bucket.** Permissões. A política nega qualquer acesso sem TLS.

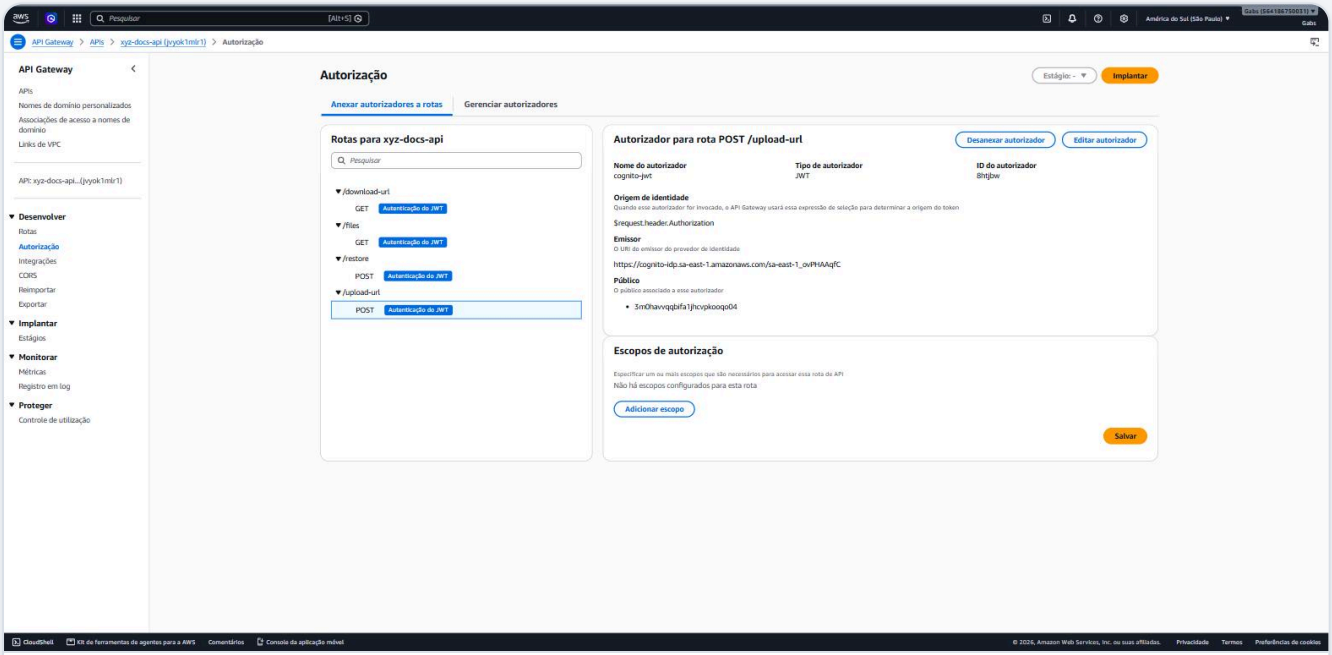


10 **"Nunca apagar".** Só o root consegue excluir uma versão de forma definitiva. Nem a aplicação nem um administrador do IAM conseguem.

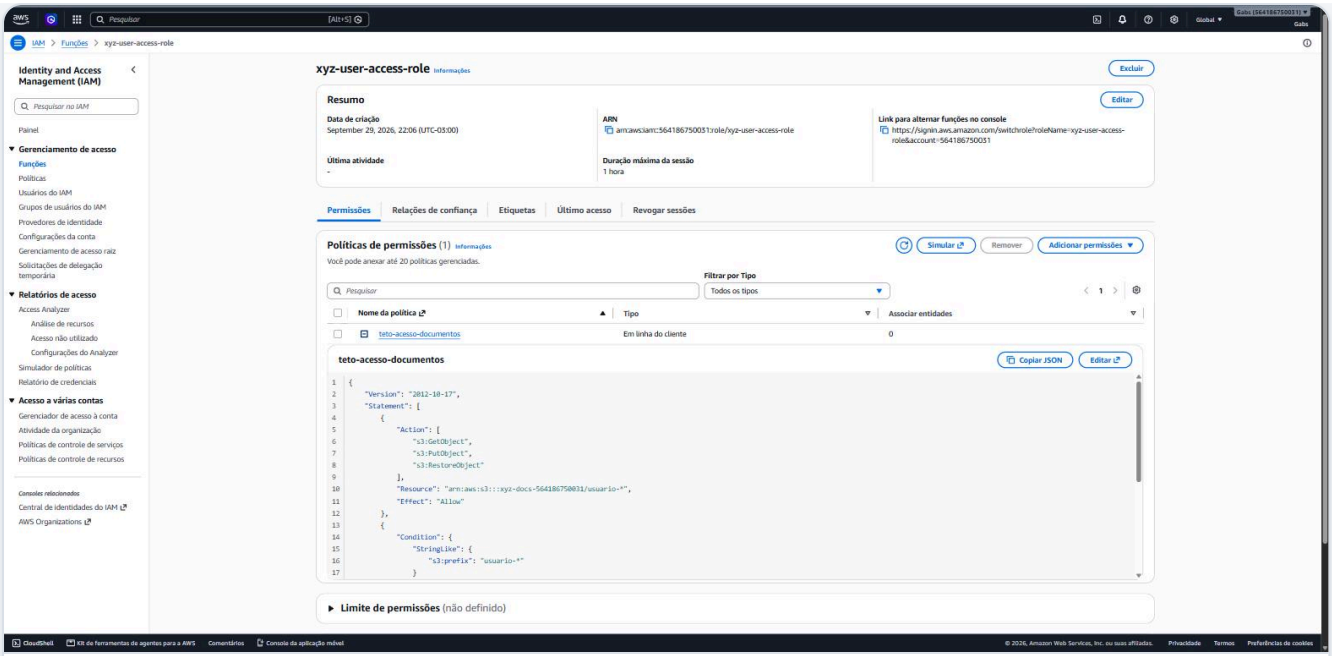


30 **Objeto cifrado.** Clique no objeto: SSE-KMS com a chave do projeto e Bucket Key ligada (menos chamadas ao KMS, menor custo).

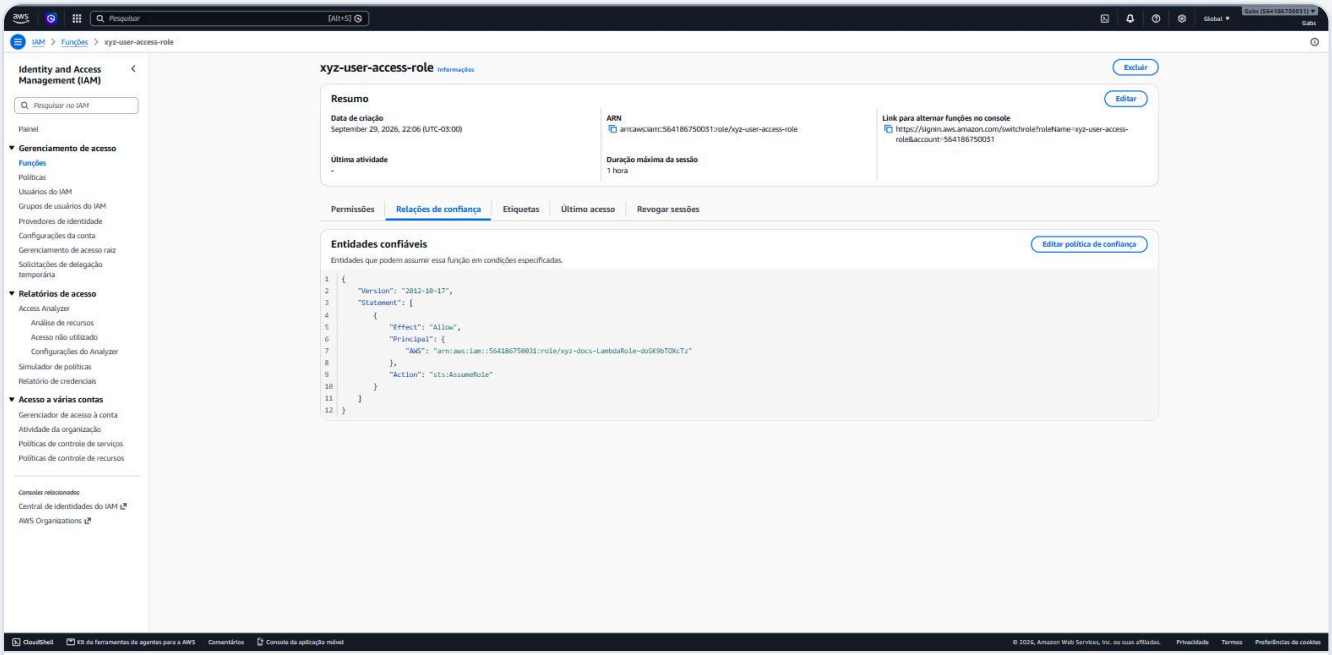
Identidade e isolamento



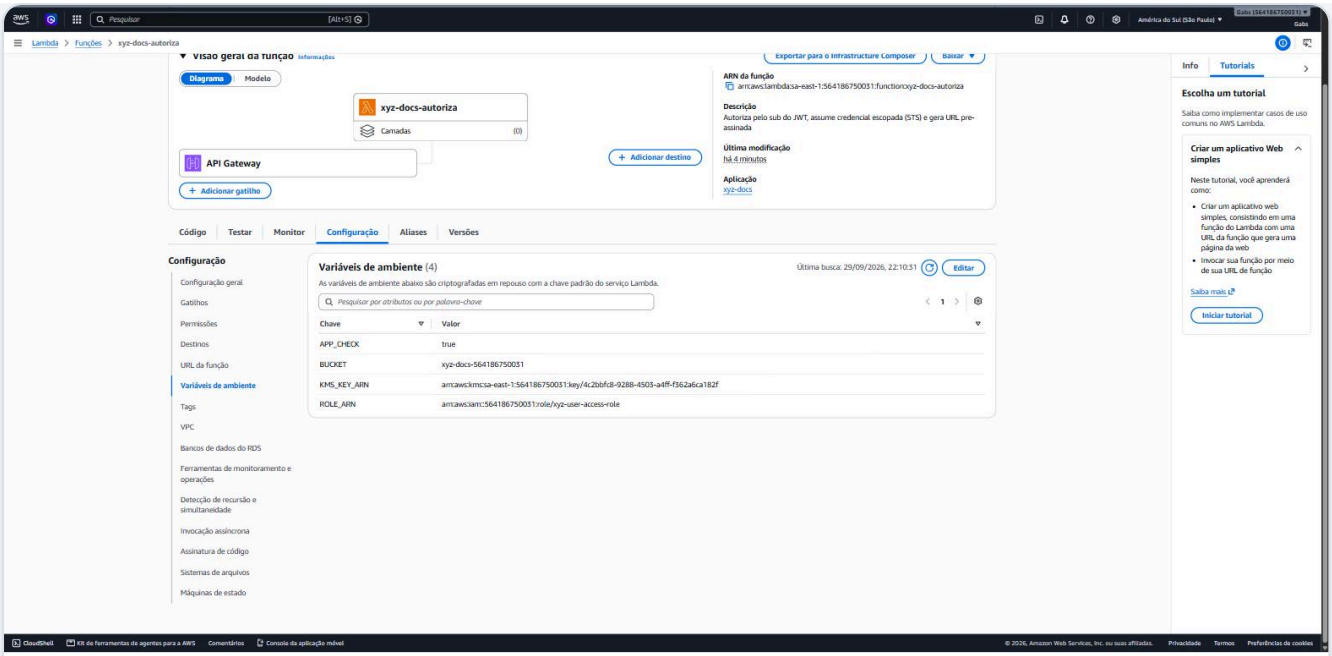
18 **Autorizador JWT.** API Gateway → xyz-docs-api → Autorização. As quatro rotas exigem token emitido pelo nosso grupo de usuários do Cognito.



20 **Teto de permissão.** IAM → Funções → `xyz-user-access-role`. A Lambda assume esta role e reduz o acesso ao prefixo de um único usuário a cada pedido.

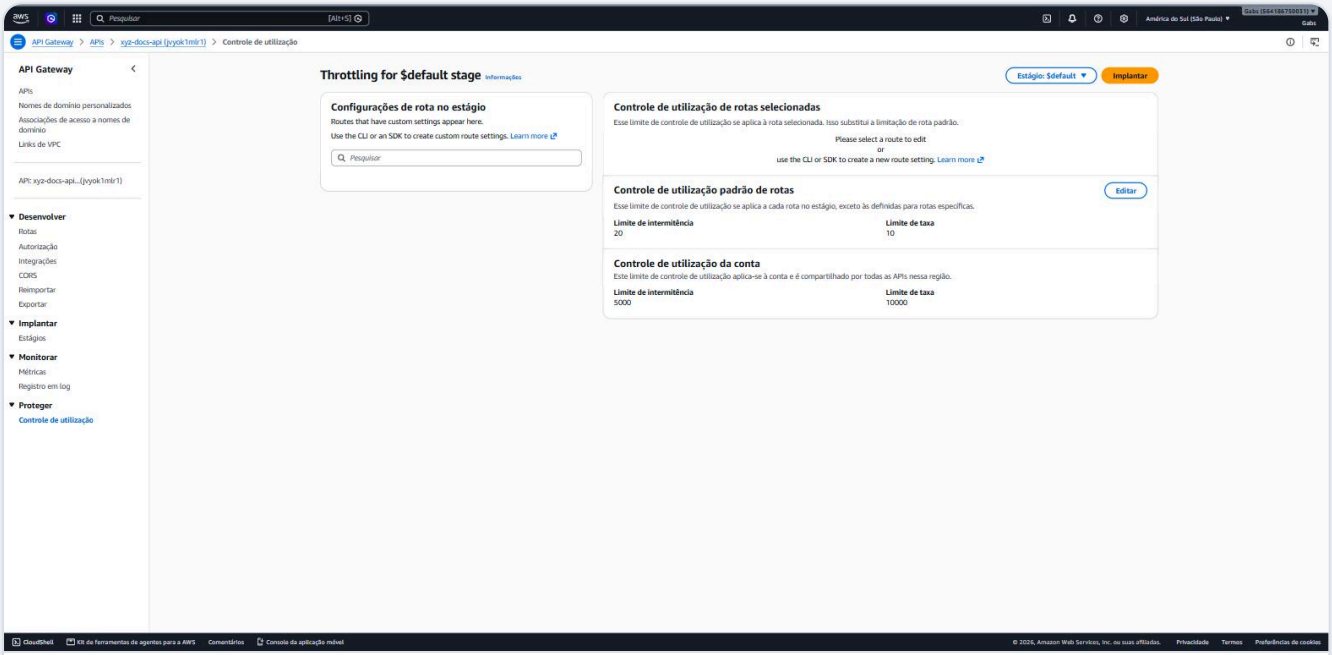


21 **Quem pode assumir.** Só a role da Lambda. A aba "Revogar sessões" invalida na hora todas as URLs já assinadas, útil se uma URL vazar.



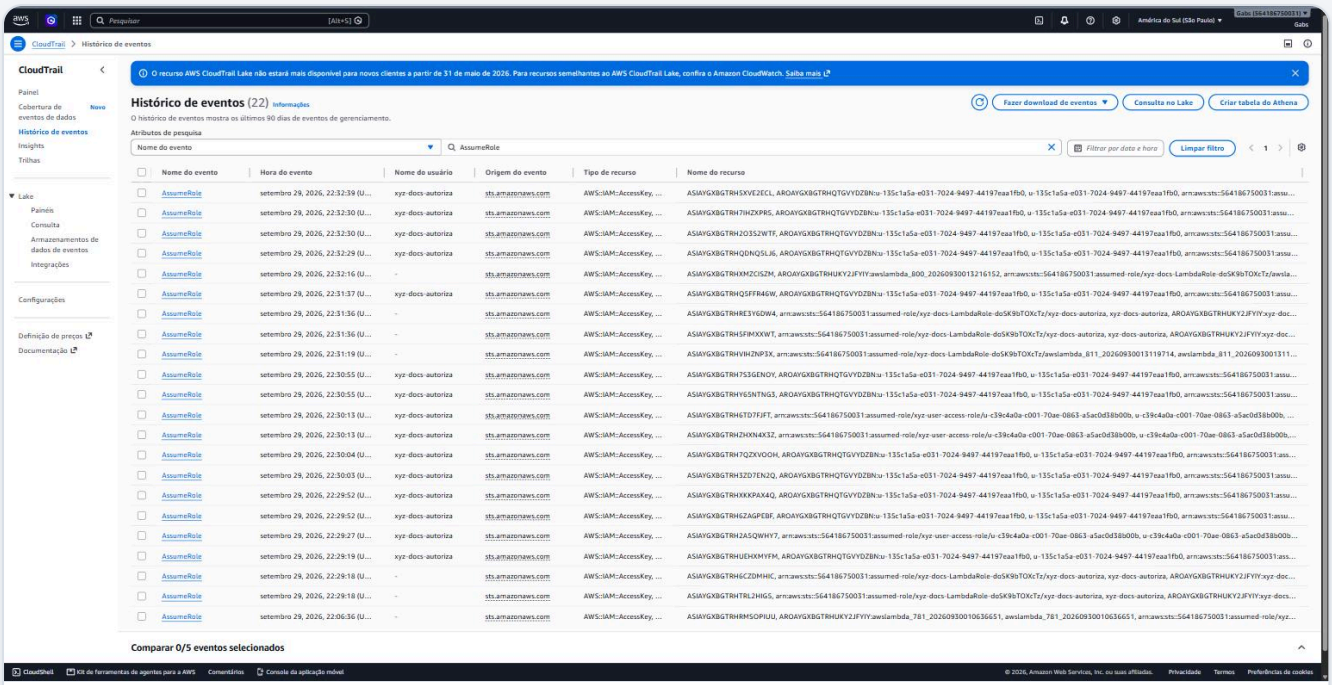
16 **Sem segredo no código.** A Lambda só recebe nomes de recursos. Credenciais vêm da role, nunca de variável ou arquivo.

Escalabilidade

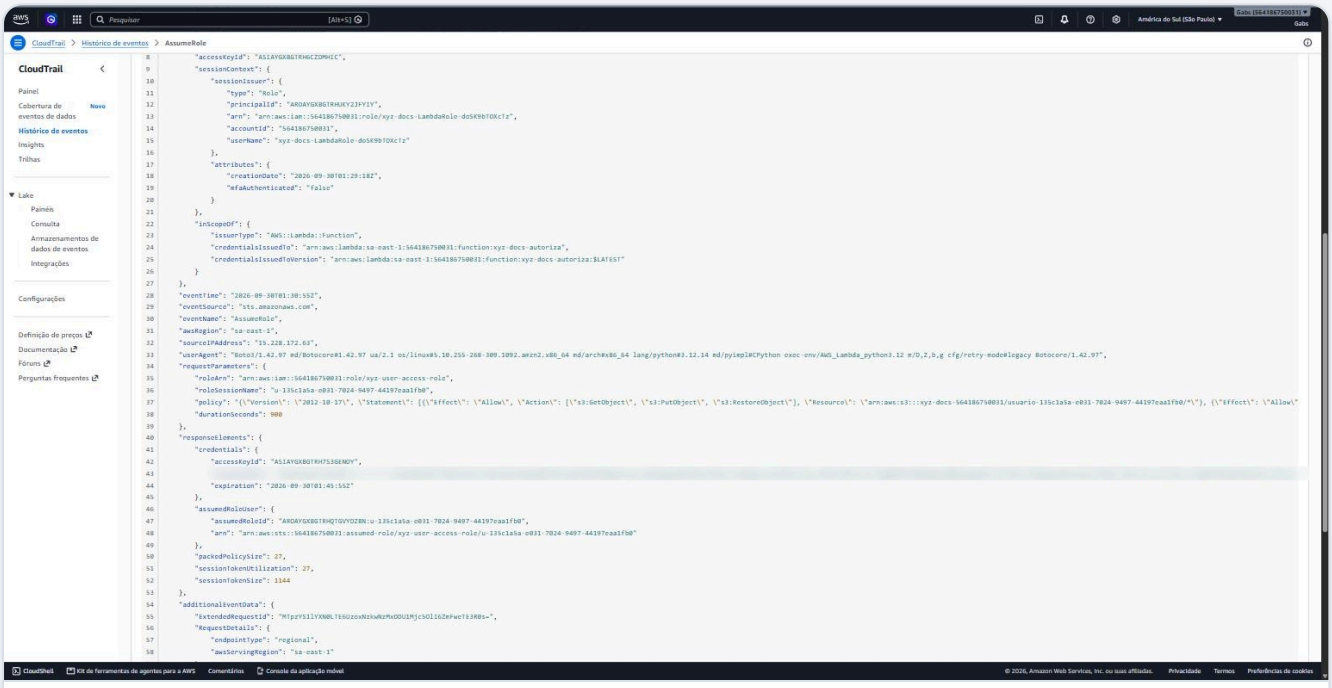


19 **Throttling.** Proteger → Controle de utilização. Nosso limite por rota: 10 req/s e pico de 20. Limite da conta: 10.000 req/s.

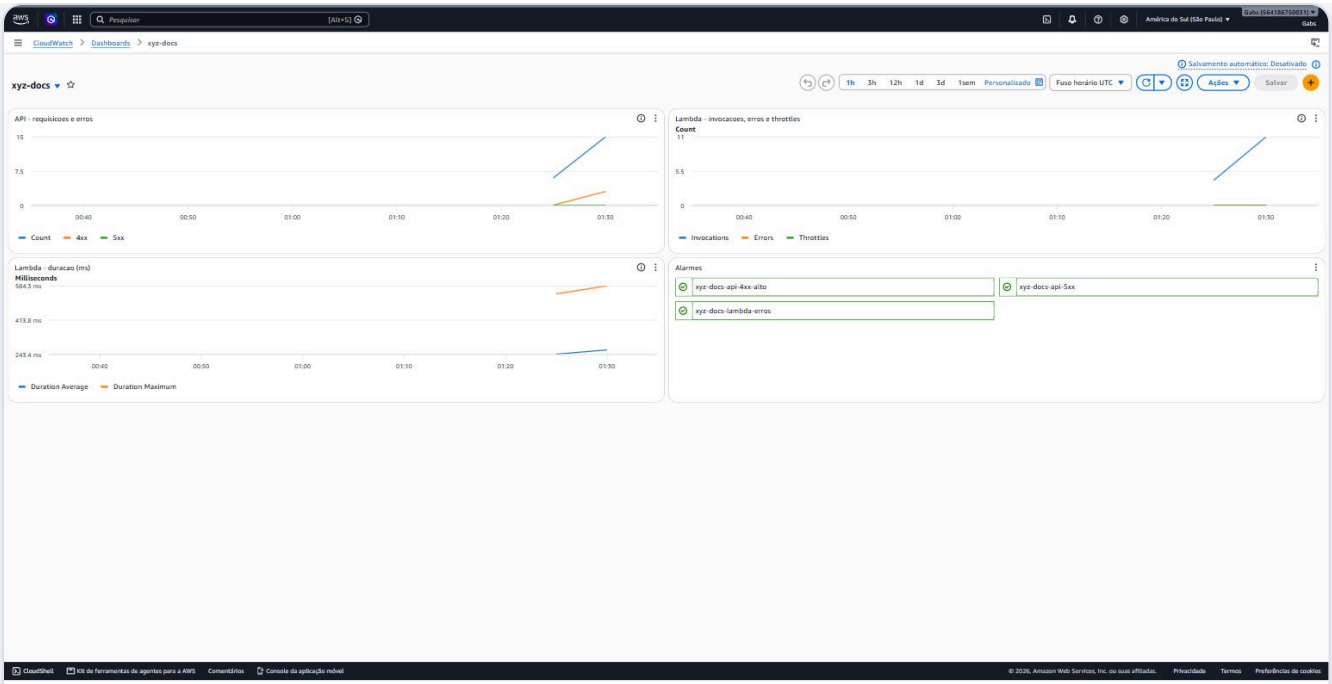
Auditoria e observabilidade



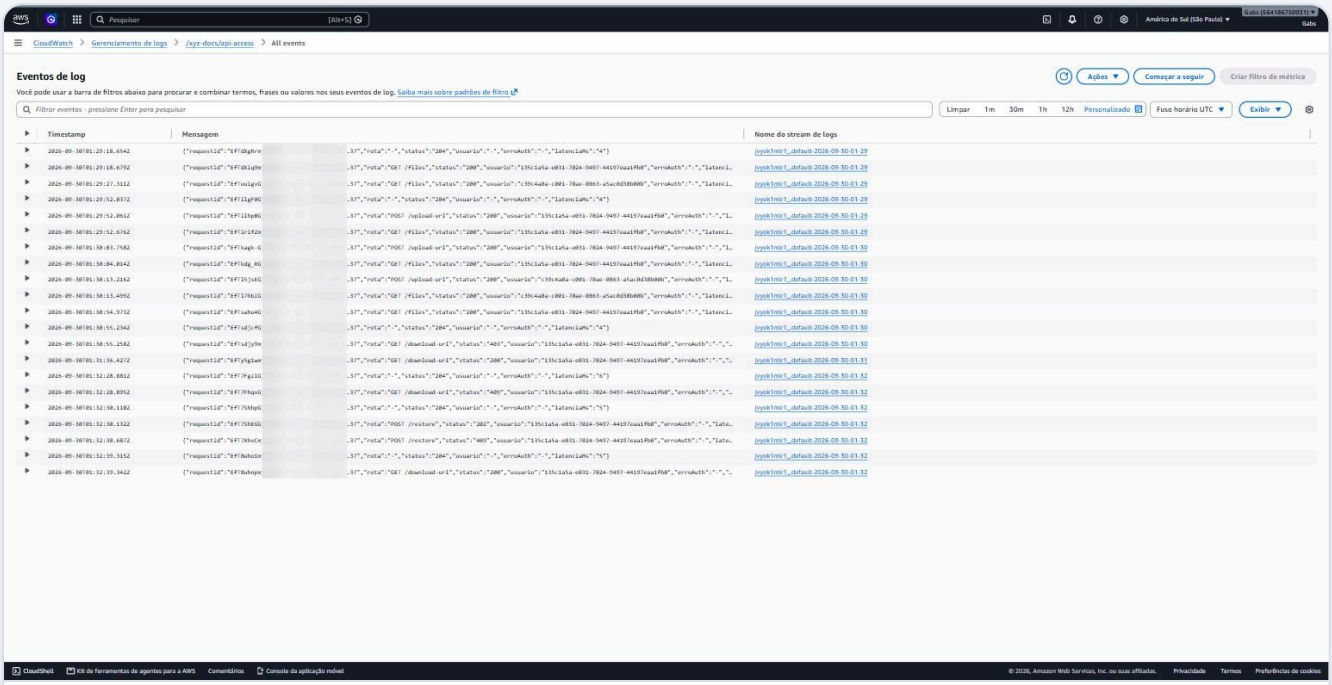
31 **Cada credencial registrada.** CloudTrail → Histórico de eventos → Nome do evento = AssumeRole. A sessão leva o `sub` do usuário no nome.



33 **A política usada fica gravada.** `requestParameters.policy` mostra o recurso restrito a `usuario/<sub>/*` e `durationSeconds: 900`. O token de sessão foi borrado no print.



34 **Dashboard xyz-docs.** Requisições e erros da API, invocações e duração da Lambda, e os três alarmes.



35 **Log de acesso da API.** Grupo `/xyz-docs/api-access`: rota, status e usuário de cada chamada, incluindo o 403 do ataque. O IP foi borrado no print.

06

Números medidos

Valores reais desta conta, para usar nos slides de escalabilidade e segurança.

MEDIDA	VALOR	ONDE VER
Duração média da Lambda (inclui a chamada ao STS)	~250 ms	Dashboard, print 34
Pior caso observado (cold start)	~580 ms	Dashboard, print 34
Validade da credencial e da URL de upload	900 s	CloudTrail, print 33
Validade da URL de download	300 s	`lambda/app.py`
Uso do limite de tamanho da session policy	27%	`packedPolicySize`, print 33
Throttling por rota / conta	10 req/s · 10.000 req/s	Print 19
50 mil documentos por mês, em média	~0,02 req/s	50.000 ÷ 30 dias ÷ 86.400 s
Tamanho máximo aceito no upload	20 MB	`content-length-range`

07

Plano B

1. **Grave a demo em vídeo na véspera** (Win + Alt + R grava a janela no Windows). Se a internet cair, mostrem o vídeo.
2. **Tenha este manual aberto.** Os prints 23 a 36 são a evidência mesmo sem conexão.
3. **Token expirou (401 no meio da demo)?** Clique em Sair e entre de novo; a lista volta.
4. **Upload falhou com erro de CORS?** A página precisa estar em `http://localhost:8000` exatamente, que é a origem liberada.

08

Apagar tudo depois da banca

1. **S3** → **bucket** `xyz-docs-…` → **Esvaziar**, logado como root. A política só deixa o root apagar versões.
2. **CloudFormation** → **pilha** `xyz-docs` → **Excluir.** Remove os outros 25 recursos.
3. **A chave KMS entra em exclusão agendada** (até 30 dias) e deixa de ser cobrada.

4. **Opcional:** esvaziar e apagar o bucket `cf-templates-…` criado pelo upload do template.

Recriar

Para apresentar de novo, repita as seções 02 e 03. Leva menos de 5 minutos.